On March 27, 2026, a critical security breach was detected targeting an internal samba server. The vulnerability allowed an unauthorized attacker to gain administrative access. The incident was successfully identified by wazuh and mitigated via CrowdSec within 5 minutes of detection. No data exfiltration was observed.

Timeline

- **13:20:00:** Initial exploitation attempts via Metasploit.
- **13:21:35:** Wazuh Manager (Agent 000) captures the shell activity and CrowdSec response.
- **13:25:00:** Attacker IP (10.0.2.15) banned and host isolation verified via ping test.
- **13:30:00:** Case escalated to Tier 2 via TheHive for forensic investigation.

Action Taken

- Action taken: Manual IP ban of the attacker (10.0.2.15) via CrowdSec.
- Command used: sudo cscli decisions add --ip 10.0.2.15 --reason "Samba RCE detected" --type ban
- Verification: Conducted a ping test from Kali to Metasploitable.
- Result: 100% Packet Loss.
- Log Evidence: Wazuh Discover (Agent 000) captured the cscli command execution, providing an audit trail of the response.

Recommendations

1. **Immediate:** disable the username map script feature in the Samba configuration.
2. **Short-term:** Implement a VLAN to isolate legacy VMs from the main network.
3. **Long-term:** Update the SOC playbook to include automated active response such as Wazuh-CrowdSec integration.